MÒDUL 06 · SEGURETAT INFORMÀTICA — RA3 · NF3-AA2

Vulnerabilitats



Amenaces, vulnerabilitats i risc: com es mesura la nostra exposició

CFGM Sistemes Microinformàtics i Xarxes · 2n curs

Institut Puig Castellar
Joan Sánchez

EN AQUESTA SESSIÓ

Què aprendrem avui?



Amenaces vs. vulnerabilitats

La diferència entre un factor extern que ens ataca i un punt feble intern del sistema.



Risc i impacte

Com es calcula i prioritza el risc real d'una vulnerabilitat concreta.



Detecció i resposta

CVE, escàners, exploits, IDS/IPS i honeypots: com detectar i respondre a intrusions.

HO SABIES?



Amenaça + vulnerabilitat = risc

No sempre és intencionat

Les amenaces no sempre són atacs deliberats: també cal considerar accidents o errors humans com a factors externs que posen en risc el sistema.

El factor humà

Bona part de les amenaces es basen en hàbits poc segurs: usar comptes d'administrador pel treball diari, obrir enllaços poc fiables, connectar pendrives desconeguts, no actualitzar el programari.

CONCEPTES CLAU

Amenaces i el seu efecte

Amenaça	Efecte sobre el sistema
Interrupció	Un recurs del sistema o de la xarxa deixa d'estar disponible.
Intercepció	Un intrús accedeix a la informació del nostre equip o de la xarxa.
Modificació	La informació ha estat alterada sense autorització.
Fabricació	Es crea un producte fals (per exemple, una pàgina web) per robar informació.

EL PUNT FEBLE

Vulnerabilitats i vulnerabilitats 0-day

- Una vulnerabilitat és un error en un sistema que permet violar la política de seguretat definida. Poden ser físiques o, més habitualment, del sistema operatiu o dels programes.
- Cal una política proactiva: actualitzacions de SO, aplicacions i firmware; estar informat de noves vulnerabilitats; utilitzar escàners de vulnerabilitats.



Vulnerabilitat 0-day: encara no ha estat reportada, per la qual cosa no existeix cap solució ni actualització que la corregeixi. Especialment perillosa.

CATALOGACIÓ

CVE: el registre mundial de vulnerabilitats

- La base de dades CVE-Mitre (Common Vulnerabilities and Exposures) assigna un identificador únic amb el format CVE-AAAA-NNNNN a cada vulnerabilitat coneguda.
- Es classifiquen per gravetat (Low/Medium/High/Critical) i amb el sistema CVSS: una puntuació numèrica de 0 a 10.



Score (0,0-10,0): calculat tècnicament (dificultat d'explotació, privilegis necessaris, impacte real). Gravetat: etiqueta de text que ajuda els equips humans a valorar la urgència sense analitzar els decimals.

PRIORITZAR

Risc = Probabilitat × Impacte

El risc total d'una organització depèn de la combinació d'ambdós factors: un impacte catastròfic amb probabilitat gairebé zero es considera un risc baix.

Escenari	Impacte	Probabilitat → Risc
Ordinador de recepció sense contrasenya, a la vista de tothom	ALT (historial mèdic confidencial)	ALTA → Risc ALT
El mateix ordinador, dins un despatx tancat amb clau	ALT (mateixes dades)	BAIXA → Risc BAIX

APROFITANT EL PUNT FEBLE

Exploits i pentesting



Exploits

Programes o tècniques que aprofiten una vulnerabilitat per aconseguir accés. Poden ser locals (cal accés físic) o remots (a través de la xarxa). Bases de dades com exploit-db en recopilen milers.



Pentesting

Proves de penetració: atacs controlats a un sistema o organització per trobar-hi vulnerabilitats i determinar la viabilitat i l'impacte real d'un atac abans que ho faci un adversari real.

PRÀCTICA REAL

Escàners de xarxa: detectant serveis exposats

- Un escàner com Nmap envia paquets a un rang d'adreces IP i ports per descobrir quins serveis estan actius i escoltant, sense necessitat que el sistema objectiu tingui cap agent instal·lat.

"nmap --top-ports 20 -sV -Pn 127.0.0.1" escaneja els 20 ports més habituals (FTP, SSH, HTTP, RDP, VNC, MySQL...) i informa de l'estat de cadascun: obert, tancat o filtrat. Un sistema ben protegit hauria de mostrar només els serveis estrictament necessaris com a "obert".

DETECTAR LA INTRUSIÓ

IDS/IPS: sistemes de detecció i prevenció



IDS (Intrusion Detection)

Compara els paquets de xarxa amb una base de dades de ciberatacs coneguts i genera una alerta davant un positiu. Exemple: Suricata (xarxa), OSSEC/Wazuh (equip).



IPS (Intrusion Prevention)

A més de detectar, actua: denega el trànsit, bloqueja la connexió. Poden protegir un equip concret (HIDS) o tota la xarxa (NIDS).

UNA TRAMPA INTEL·LIGENT

Honeypots



Equips que simulen ser una víctima real, per registrar les accions de l'atacant, veure quins mètodes utilitza i, mentre l'atacant hi perd el temps, mantenir els sistemes reals fora de perill.

- També pot permetre identificar l'atacant en alguns casos.
- Exemples: T-Pot, FaPro.

SEMPRE ÚTIL

Inspecció de logs



La revisió dels logs no evita un atac, però permet determinar que s'ha patit un incident, i sobretot COM s'ha produït, cosa que permet prendre mesures perquè no torni a passar. Els atacants sovint intenten esborrar-los per eliminar-ne el rastre — però això mateix ja és un indici d'atac.

PER ACABAR

Idees clau d'avui



Amenaça + vulnerabilitat

La combinació determina el risc; cal quantificar-lo (probabilitat × impacte) per prioritzar-lo bé.



CVE i escàners

El registre CVE i eines com Nmap permeten identificar vulnerabilitats i serveis exposats de manera sistemàtica.



Detecció contínua

IDS/IPS, honeypots i logs: la seguretat no acaba en prevenir, cal poder detectar quan alguna cosa ha fallat.

ARA ÉS EL TORN VOSTRE

Un servidor web de l'empresa executa una versió de programari amb una vulnerabilitat 0-day recentment publicada, encara sense pedaç oficial.

En parelles: proposeu 3 mesures de mitigació temporal (sense poder actualitzar) que reduirien el risc mentre s'espera el pedaç, i expliqueu com les prioritzaríeu segons la fórmula risc = probabilitat × impacte.

10 minuts en parelles + posada en comú

FONTS DEL MATERIAL

Webgrafia

NF3-AA2: Vulnerabilitats

Repositori "Materials" (GitHub, SMX-0226SI) · Carlos Alonso Martínez, Escola Pia de Mataró · Llicència CC-BY-SA-4.0

CVE — Common Vulnerabilities and Exposures

cve.mitre.org

INCIBE-CERT — Guía de gestión de riesgos

incibe.es/empresas/guias/gestion-riesgos-guia-empresario

Nmap — Network Mapper

nmap.org

Llicència CC BY-SA 4.0 · Adaptat de "Materials" (SMX-0226SI), Carlos Alonso Martínez, Escola Pia de Mataró